

1. Session Hijacking Concepts

What is Session Hijacking?

An attack where an attacker seizes control of a valid TCP communication session between two computers. Since most authentication occurs only at the start of a TCP session, this allows the attacker to gain unauthorized access to a machine once a session is in progress. The attacker steals a valid session ID (token) and uses it to authenticate themselves with the server.

- **Session Token/ID:** A unique identifier sent by a web server to a client after successful authentication, differentiating multiple sessions.
- Attackers can sniff traffic from established sessions to perform identity theft, information theft, fraud, etc.
- Can be used to launch Man-in-the-Middle (MITM) and Denial-of-Service (DoS) attacks.

Why is Session Hijacking Successful?

- **Absence of account logout for invalid session IDs:** Allows brute-force attempts on session IDs without penalty.
- **Weak session-ID generation algorithm or small session IDs:** Predictable or short IDs are easier to guess or brute-force.
- **Insecure handling of session IDs:** Session IDs can be retrieved through DNS poisoning, Cross-Site Scripting (XSS), or browser bugs.
- **Indefinite session timeout:** "Remember me" options or long session durations give attackers more time to exploit captured session IDs.
- **Vulnerability of TCP/IP:** Design flaws inherent in TCP/IP make all machines running it vulnerable.
- **Lack of Encryption:** Easy to sniff session IDs in plaintext if transport security (SSL/TLS) is not properly implemented.

Session Hijacking Process

1. **Sniff:** Attacker places themselves between the victim and the target to sniff network traffic and capture session information (e.g., sequence numbers).
2. **Monitor:** Monitor the flow of packets to predict sequence and acknowledgment numbers.
3. **Session Desynchronization:** Break the legitimate connection between the victim and the server by injecting packets (e.g., sending null data to advance SEQ/ACK numbers, or RST/FIN flags to reset/close connection on server side).
4. **Session ID Prediction:** Predict the next valid session ID or use the captured one to take over the session.
5. **Command Injection:** Start injecting malicious packets to the target server, impersonating the legitimate user.

Types of Session Hijacking

- **Passive Session Hijacking:** Attacker observes and records all traffic during the session without active interference. Used to obtain user IDs and passwords for later login. Difficult to detect.
- **Active Session Hijacking:** Attacker takes over an existing session by breaking the connection of the legitimate user or actively participating in the conversation (MITM). More detectable.

Session Hijacking in OSI Model

- **Network-Level Hijacking:** Intercepts packets during TCP or UDP sessions (e.g., TCP/IP hijacking, UDP hijacking). Does not require host access.
- **Application-Level Hijacking:** Gains control over HTTP user sessions by obtaining session IDs. Focuses on web applications.

Spoofing vs. Hijacking

- **Spoofing:** Attacker pretends to be another user or machine by forging credentials or IP/MAC addresses. Initiates a *new* session using stolen credentials.
- **Hijacking:** Attacker takes *control of an existing, active session* after authentication has already occurred.

2. Application-Level Session Hijacking

This focuses on web application sessions, often by compromising the session token.

An attacker implements various techniques such as stealing, guessing, and brute forcing to obtain a valid session ID, which helps in acquiring control over a valid user's session while it is in progress.

Compromising Session IDs using Sniffing

- An attacker uses a sniffer to capture a valid session token or session ID
- The attacker then uses the valid token session to gain unauthorized access to the web server

Compromising Session IDs by Predicting Session Token

Attackers can predict session IDs generated by weak algorithms and impersonate a website user

- Attackers analyze variable sections of session IDs to determine a pattern

The analysis is performed manually or using various cryptanalytic tools

- Attackers collect a high number of simultaneous session IDs to gather samples in the same time window and keep the variable constant

Therefore, a hacker can determine the generated session ID in the following ways:

- Embed in URL.
- Embed into form as hidden field using HTTP POST method.
- Embedded in a cookie on the client's local machine.

Hacker guesses unique session value or deduces session ID. As shown in the image below, hacker first captures some session ID and analyzes the pattern.

```
http://www.certifiedhacker.com/view/JBEX12042022152820
http://www.certifiedhacker.com/view/JBEX12042022153020
http://www.certifiedhacker.com/view/JBEX12042022160020
http://www.certifiedhacker.com/view/JBEX12042022164020
```

Constant Date Time

How to Predict a Session Token :Analyzing Token Patterns

Sequential Tokens ☺ Timestamp-based Tokens ☺ Brute Force Attacks Small Token Space

Weak Random Number Generators Predictable PRNG

Predictable PRNGs can produce token sequences that attackers can guess if they know the seed or algorithm

Lack of Rate Limiting

Without rate limiting, attackers can make numerous token guesses without being blocked

Compromising Session IDs Using Man-in-the-Middle/ Manipulator-in-the-Middle Attack

The man-in-the-middle/manipulator-in-the-middle attack is used to intrude into an existing connection between systems and intercept the messages being exchanged

- Attackers use different techniques and split the TCP connection into two connections:
- Client-to-attacker connection • Attacker-to-server connection
- After the interception of the TCP connection, an attacker can read, modify, and insert fraudulent data into the intercepted communication
- In the case of an http transaction, the TCP connection between the client and the server becomes the target

Compromising Session IDs Using Man-in-the-Browser / Manipulator-in-the-Browser Attack

The man-in-the-browser/manipulator-in-the-browser attack uses a Trojan horse to intercept the calls between the browser and its security mechanisms or libraries

Compromising Session IDs using Client-side Attacks:

Cross-Site Scripting (XSS): Injecting malicious client-side scripts to steal cookies or session info.

Cross-Site Request Forgery (CSRF): Tricks a user's browser into performing unwanted actions on a trusted site by exploiting implicit trust.

- **Client-side attacks:** Using XSS (Cross-Site Scripting) or malicious JavaScript to steal cookies containing session IDs.
- **Malicious JavaScript Codes:** Injected scripts that capture tokens.
- **Trojans:** Malware that intercepts session data.

Compromising Session IDs Using Session Replay Attacks

In a session replay attack, the attacker listens to the conversation between the user and the server and captures the authentication token of the user

- Once the authentication token is captured, the attacker replays the request to the server with the captured authentication token and gains unauthorized access to the server

A session fixation attack has the following three phases:

Session set-up phase: In this phase, the attacker first obtains a legitimate session ID by establishing a connection with the target web server. Few web servers support the idle session time-out feature. If the target web server supports this feature, the attacker needs to send requests repeatedly to keep the established trap session ID alive.

Fixation phase: In this phase, the attacker introduces the session ID to the victim's browser, thereby fixing the session.

Entrance phase: In this phase, the attacker waits for the victim to log in to the target web server using the trap session and then enters the victim's session.

Brute forcing: In the brute-force technique, an attacker obtains session IDs by attempting all possible permutation session ID values until finding one that works.

Compromising Session IDs Using Session Fixation

- Session fixation is an attack that allows an attacker to hijack a valid user session
- An attacker attempts to lure a user to authenticate himself or herself with a known session ID and then hijacks the user-validated session with the knowledge of the used session ID
- The attacker has to provide a legitimate web application session ID and attempt to lure the victim's browser to use it
- Some techniques for executing session fixation attacks are as follows:
Login with the same SID
- Session token in the URL argument • Session token in a hidden form field • Session ID in a cookie

Session Hijacking Using Proxy Servers

- An attacker lures the victim to click on a bogus link, which looks legitimate but redirects the user to the attacker server
- The attacker forwards the request to the legitimate server on behalf of the victim and serves as a proxy for the entire transaction
- The attacker then captures the session's information during the interaction of the legitimate server and user

Session Hijacking Using CRIME Attack

- Compression Ratio Info-Leak Made Easy (CRIME) is a client-side attack that exploits the vulnerabilities present in the data compression feature of protocols, such as SSL/TLS, SPDY, and HTTPS
- Attackers hijack the session by decrypting secret session cookies
- The authentication information obtained from the session cookies is used to establish a new session with the web application

Session Hijacking Using Forbidden Attack

- A forbidden attack is a type of man-in-the-middle attack used to hijack HTTPS sessions • It exploits the reuse of cryptographic nonce during the TLS handshake
- After hijacking the HTTPS session, the attackers inject malicious code and forged content that prompts the victim to disclose sensitive information, such as bank account numbers, passwords, and social security numbers

Session Hijacking Using Session Donation Attack

In a session donation attack, an attacker donates his/her own session identifier (SID) to the target user

- The attacker first obtains a valid SID by logging into a service and later feeds the same SID to the target user • This SID links a target user back to the attacker's account page without any information to the victim

Network-Level Session Hijacking

- The network-level hijacking relies on hijacking transport and Internet protocols used by web applications in the application layer
 - By attacking the network-level sessions, the attacker gathers some critical information, which are used to attack the application-level sessions
- Network-level hijacking includes:

1. **TCP/IP Hijacking:** Attacker intercepts and takes over an established TCP connection between two communicating parties by spoofing packets. Involves sniffing, desynchronization, and command injection.
2. **Blind Hijacking:** Attacker injects malicious data/commands without seeing the response from the server.
3. **IP Spoofing (Source Routed Packets):** Attacker uses source routing to specify the path of packets, allowing them to hide their true IP and inject into a trusted host's session.
4. **RST Hijacking:** Attacker injects an authentic-looking RST packet with a spoofed source IP and predicted sequence/acknowledgment numbers to reset the victim's connection.
5. **UDP Hijacking:** Similar to TCP hijacking but for UDP sessions. More challenging due to stateless nature, but no sequence numbers make it less complex than TCP.
6. **MITM Attack using Forged ICMP and ARP Spoofing:** Attacker intercepts communication by forging ICMP redirect messages or ARP replies to reroute traffic through their machine.
7. **PetitPotam Hijacking:** Attack where attacker forces a domain controller to initiate authentication to their server, allowing them to relay NTLM credentials and gain admin privileges.

Session Hijacking Tools Hetty

Hetty is an HTTP toolkit that allows attackers to perform machine-in-the-middle (MITM) HTTP proxy attack using logs and advanced search

Caído is a web security auditing toolkit that security professionals can use to intercept and view HTTP requests in real-time while browsing

5. Session Hijacking Countermeasures

Protecting against session hijacking requires robust security practices across all layers.

Session Hijacking Detection Methods

- **Manual Method:** Using packet sniffing software (Wireshark, SteelCentral Packet Analyzer) to monitor network traffic for suspicious patterns (repeated ARP updates, ACK storms, different MAC addresses for client/server).
- **Automatic Method:** Using Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS) to monitor incoming network traffic for attack signatures.

Protecting against Session Hijacking (General)

- **Use Secure Shell (SSH) / OpenSSH:** To create secure communication channels.
- **Pass authentication cookies over HTTPS connections:** Always use HTTPS.
- **Implement log-out functionality:** For user to end the session properly.
- **Generate Session IDs after successful login:** New ID after authentication.
- **Encrypt data in transit:** Ensures data is encrypted during transmission.
- **Use strong or long random numbers as session keys:** Makes session ID prediction difficult.
- **Use different usernames and passwords for different accounts.**
- **Educate employees:** Minimize remote access.
- **Implement timeout mechanism:** Automatically expire inactive sessions.

- **Avoid session ID in URL:** Don't include session IDs in the URL query string.
- **Switch from a hub to a network switch:** (Hubs are outdated, but switches provide isolation).
- **IDS products or ARPwatch:** For monitoring ARP cache poisoning.
- **Firewalls and browser settings:** To confine cookies.
- **Protect authentication cookies with Secure Sockets Layer (SSL).**
- **Regularly update platform patches:** To fix TCP/IP vulnerabilities.
- **Use IPsec:** To encrypt session information.
- **Verify website authenticity:** Network notary services.
- **Implement DNS-based authentication:** For named entities.
- **Disable HTTP request compression.**
- **Restrict Cross-Site Scripting (XSS) and Cross-Site Request Forgery (CSRF).**
- **Upgrade web browsers to latest versions.**
- **Vulnerability scanners:** To detect insecure HTTPS session settings.
- **Enable HTTPOnly property:** Prohibit user scripts from accessing cookies.
- **SSH file transfer protocol (SFTP), Applicability Statement 2 (AS2)-managed file transfer, or FTP Secure (FTPS):** Secure file transfers.
- **Microsoft-based solution (SMB signing):** To enable traffic signing.
- **Secure socket layer (SSL) or transport layer security (TLS):** To decrease chances of successful hijacks.
- **Implement IPsec:** To secure IP communications.
- **Encrypted virtual private networks (VPNs):** For remote connections.
- **Multi-factor authentication (MFA):** To reduce chances of unauthorized access.
- **Samesite cookie attribute:** To prevent sending cookies along with cross-site requests.
- **Monitor unusual patterns:** For multiple simultaneous logins from different locations.
- **Educate users on application logging and unique passwords.**
- **Bind the session to the user's IP address.**

Approaches to Prevent Session Hijacking (Specifics)

- **HTTP Strict Transport Security (HSTS):** Forces browsers to interact with HTTPS websites only, preventing MITM downgrade attacks.
- **Token Binding:** Binds authentication tokens/cookies to the client's TLS session to prevent their theft or misuse.
- **Prevent MITM Attacks:**

- **DNS over HTTPS (DoH):** Encrypts DNS queries to prevent DNS spoofing.
- **WPA3 Encryption:** For secure wireless networks.
- **VPN:** Encrypted tunnel for secure communication.
- **Two-Factor Authentication:** Adds a second layer of proof.
- **Password Manager:** Securely stores unique, complex passwords.
- **Zero-trust Principles:** Verify every user and device before granting access.
- **Public Key Infrastructure (PKI):** Manages digital certificates for secure communication.
- **Network Segmentation:** Divides network to limit attacker's ability to move laterally.
- **IPsec (Internet Protocol Security):** A suite of protocols providing secure exchange of packets at the IP layer. Offers authentication, data integrity, confidentiality, and replay protection.
 - **Transport Mode:** Encrypts only the payload.
 - **Tunnel Mode:** Encrypts the entire IP packet (payload + IP header), used for VPNs.

Session Hijacking Prevention Tools

- **Checkmarx One SAST:** Source-code analysis for vulnerabilities.
- **Fiddler:** Web debugging proxy to intercept and modify HTTP/HTTPS traffic.
- **Nessus:** Vulnerability scanner.
- **Invicti/Wapiti:** Web application security scanners.

Session Hijacking Detection Tools

- **USM Anywhere (AT&T Cybersecurity):** Unified security management platform.
- **Wireshark:** Network protocol analyzer.
- **Quantum Intrusion Prevention System (Check Point).**
- **SolarWinds Security Event Manager.**
- **IBM Security Network Intrusion Prevention System.**
- **LogRhythm.**

Key Terms for Last-Minute Revision

- **Session Hijacking:** Seizing control of an active communication session.
- **Session ID/Token:** Unique identifier for a user's session.
- **TCP/IP Hijacking:** Taking over an active TCP connection.
- **UDP Hijacking:** Taking over an active UDP session.
- **Man-in-the-Middle (MITM):** Attacker intercepts and relays communication.

- **Man-in-the-Browser (MITB):** Trojan-based MITM that modifies browser activity.
- **Cross-Site Scripting (XSS):** Injecting malicious scripts to steal session IDs.
- **Cross-Site Request Forgery (CSRF):** Tricking browser to perform unwanted actions.
- **Session Replay Attack:** Replaying captured authentication tokens.
- **Session Fixation:** Forcing a user to use a predictable session ID.
- **CRIME Attack:** Exploits TLS/SSL compression to decrypt cookies.
- **Forbidden Attack:** MITM using cryptographic nonce.
- **Session Donation Attack:** Attacker gives a victim a session ID and then hijacks it.
- **PetitPotam Hijacking:** Exploits MS-EFSRPC to gain admin privileges.
- **HSTS (HTTP Strict Transport Security):** Forces HTTPS communication.
- **Token Binding:** Binds tokens to TLS session to prevent misuse.
- **DNS over HTTPS (DoH):** Encrypts DNS queries.
- **IPsec:** Suite of protocols for secure IP communication (Transport & Tunnel modes).
- **2FA/MFA:** Two-Factor/Multi-Factor Authentication.
- **IDS/IPS:** Intrusion Detection/Prevention Systems (detection).
- **Wireshark:** Packet sniffing tool.
- **Honeypots:** Decoy systems for detection.
- **Egress/Ingress Filtering:** Network traffic control.
- **Port Security:** Switch security feature.
- **VLAN Hopping:** Bypassing VLAN segmentation.

Which of the following IPsec components uses the Diffie–Hellman algorithm to create a master key and a key that is specific to each session in IPsec data transfer? Oakley